

20/11/2025

Etude de la Sécurité des Systèmes d'Information chez B&B Hotels selon le référentiel de la CNIL

Guide pratique RGPD : Sécurité des données
personnelle



utt
UNIVERSITÉ DE TECHNOLOGIE
TROYES



Responsable pédagogique:

Marc LEMERCIER

Shakira IPOULE
RT3

Table des matières

Introduction.....	3
I. Recensement des traitements des données personnelles chez B&B Hotels	3
1. Description générale	3
2. Traitements identifiés et données concernées.....	4
2.1. Gestion des réservations	4
2.2. Facturation et gestion financière	4
2.3. Gestion de la relation client et réclamations.....	5
2.4. Marketing digital et prospection commerciale.....	5
2.5. Gestion du Wi-Fi hôtelier	5
2.6. Gestion du personnel et candidatures	6
2.7. Vidéoprotection.....	6
2.8. Fiches individuelles de police.....	7
2.9. Gestion des contentieux et sinistres	7
2.10. Classification de données traitées.....	7
3. Supports matériels et techniques des traitements	11
3.1. Matériels informatiques.....	11
3.3. Logiciels et systèmes.....	11
3.3. Canaux de communication.....	12
3.4. Supports papier	12
3.5. Locaux et installations physiques.....	13
I. Question N°3 : Mises à jour régulières.....	13
II. Appréciation des risques liés aux traitements.....	13
III. Mise en œuvre de mesures de sécurité.....	14
1. Fiche 1 : Sensibiliser et former les utilisateurs	14
2. Fiche 2 : Gérer les habilitations et accès	15
3. Fiche 3 : Authentifier les utilisateurs.....	17
4. Fiche 4 : Tracer les opérations et gérer les incidents	19
5. Fiche 5 : Sécuriser les postes de travail	20
6. Fiche 6 : Sécuriser l'informatique mobile.....	22
7. Fiche 7 : Protéger le réseau informatique interne	23
8. Fiche 8 : Sécuriser les serveurs.....	25
9. Fiche 9 : Sécuriser les sites web et applications	27

10.	Fiche 10 : Sauvegarder et prévoir la continuité d'activité.....	28
11.	Fiche 11 : Archiver de manière sécurisée.....	30
12.	Fiches 12-14 : Développement, maintenance, sous-traitance, échanges externes	32
13.	Fiche 15 : Protéger les locaux.....	33
14.	Fiche 16 : Chiffrer, hacher, signer les données.....	35
15.	Fiche 17 : Evaluer le niveau de sécurité.....	36
Conclusion		38
Annexe.....		38

Introduction

La sécurité des systèmes d'information dans le secteur hôtelier est aujourd'hui une nécessité cruciale face à l'augmentation constante des cybermenaces. Les hôtels, comme B&B Hotels, manipulent des volumes importants de données personnelles sensibles (identités, réservations, préférences, paiements), qui constituent des cibles privilégiées pour les cyberattaques. La compromission de ces données peut entraîner des fuites, des fraudes ou des atteintes à la vie privée des clients, en plus d'exposer l'établissement à des sanctions réglementaires sévères. La protection de ces informations repose sur une stratégie de sécurité des systèmes d'information structurée, combinant des mesures techniques et organisationnelles, conformes au RGPD et aux recommandations de la CNIL. La sensibilisation du personnel, la sécurisation des réseaux, la gestion rigoureuse des accès et la mise en place d'un plan d'urgence sont autant de leviers pour réduire les risques et renforcer la confiance des clients dans la fiabilité de leur séjour.

Nous examinerons dans un premier temps le recensement des traitements mis en œuvre par l'hôtel. Ensuite, nous analyserons les risques liés à ces traitements afin de mieux comprendre les vulnérabilités. Enfin, nous proposerons des mesures concrètes pour renforcer la sécurité des systèmes d'information de B&B Hotels, conformément aux 17 fiches du guide de la CNIL, afin d'assurer une protection optimale des données.

I. Recensement des traitements des données personnelles chez B&B Hotels

1. Description générale

B&B Hotels est un groupe hôtelier français qui opère un réseau d'établissements d'hébergement à travers la France. Dans le cadre de ses activités, B&B Hotels traite des données personnelles relatives à ses clients (réservations, séjours, facturation), ses prospects (prospection commerciale), ses employés (gestion RH) et ses partenaires commerciaux.

L'objectif principal de ces traitements est de permettre la gestion opérationnelle des établissements hôteliers : accueil des clients, gestion des réservations, facturation et paiement des services, amélioration de la qualité de service, fidélisation de la clientèle, conformité aux obligations légales et administratives, ainsi que la sécurité de l'entreprise et de ses systèmes d'information.

Le responsable de traitement principal est B&B HOTELS FRANCE (SARL, immatriculée au RCS Brest 378 047 500), basée à 271 rue du Général Paulet, 29200 Brest. Le Délégué à la Protection des Données (DPO) est joignable à dpo-france@hotelbb.com ou privacy.france@hotelbb.com

2. Traitements identifiés et données concernées

2.1. Gestion des réservations

Le traitement de gestion des réservations vise à enregistrer, confirmer et suivre les réservations de séjours des clients dans les hôtels B&B Hotels.

Il englobe également la gestion de la communication pré et post-séjour (envoi de confirmations, rappels de réservation, accès à distance à l'établissement), la fourniture de services de conciergerie en ligne (e-conciergerie) permettant aux clients de formuler des demandes spécifiques, ainsi que la gestion du check-in et check-out.

Ces traitements reposent sur l'exécution du contrat de réservation conclu entre B&B Hotels et le client. Pour les services d'e-conciergerie, le traitement requiert également le consentement explicite du client.

Les données traitées sont accessibles au personnel hôtelier habilité (réception, commercial, administratif), aux autres établissements du réseau B&B Hotels, ainsi qu'aux sous-traitants intervenant dans la chaîne de réservation : plateformes en ligne (Booking.com, Expedia, Hotels.com), prestataire de paiement (Adyen) et hébergeur de données (Datacampus).

2.2. Facturation et gestion financière

Le traitement de facturation et gestion financière a pour objectif d'émettre les factures relatives aux prestations fournies, d'encaisser les paiements sécurisés, d'assurer la tenue comptable de l'établissement et de répondre aux obligations fiscales et sociales. Il comprend également la gestion du recouvrement des impayés.

Ces traitements reposent sur l'exécution du contrat de réservation, les obligations légales imposées par le Code du commerce (conservation comptable de 10 ans), les obligations fiscales et sociales (déclarations URSSAF), ainsi que sur l'intérêt légitime de B&B Hotels en matière de recouvrement des créances.

Les données bancaires sensibles (numéro de carte, cryptogramme) sont traitées exclusivement par le prestataire de paiement Adyen (certifié PCI DSS), qui retourne uniquement un jeton d'identification sécurisé.

Les destinataires sont le personnel financier et comptable, la direction, les experts-comptables, les commissaires aux comptes, le prestataire Adyen, ainsi que les organismes de recouvrement en cas d'impayé.

2.3. Gestion de la relation client et réclamations

Le traitement de gestion de la relation client vise à assurer le suivi personnalisé des clients, traiter leurs réclamations et demandes, recueillir leur satisfaction via des enquêtes, gérer le programme de fidélité (gratuit et payant) et collecter les avis clients publiés sur les réseaux sociaux et plateformes partenaires.

Ces traitements reposent sur l'exécution du contrat pour les réclamations liées aux prestations, l'intérêt légitime de B&B Hotels pour améliorer la qualité de service et mesurer la satisfaction client, ainsi que le consentement pour l'adhésion au programme de fidélité.

Les données sont accessibles au personnel commercial, au service client, à la direction, aux assureurs en cas de sinistre, aux avocats et médiateurs en cas de litige, ainsi qu'au prestataire CRM Salesforce (encadré par des Clauses Contractuelles Types pour les transferts vers les États-Unis).

2.4. Marketing digital et prospection commerciale

Le traitement de marketing digital et prospection commerciale a pour finalité l'envoi de newsletters, la réalisation de campagnes de prospection personnalisées par email, SMS ou appels téléphoniques, la diffusion de publicités ciblées sur les réseaux sociaux et moteurs de recherche, ainsi que l'analyse d'audience du site web et de l'application mobile via l'utilisation de cookies et traceurs.

Ces traitements reposent sur le consentement des personnes concernées pour l'envoi d'emails et SMS à des fins de prospection (conformément à l'article L.34-5 du Code des Postes et Communications Électroniques), ainsi que sur l'intérêt légitime pour la prospection téléphonique B2B et l'envoi d'emails B2B concernant des produits analogues. La gestion des consentements est assurée via l'outil Tarteaucitron, dont la durée de validité est de 6 mois.

Les destinataires sont l'équipe marketing interne, les agences marketing externes, les régies publicitaires (Google Ads, Meta, Criteo, Dynatrace), les partenaires réseaux sociaux (Facebook, Instagram, TikTok, YouTube), ainsi que le prestataire Tarteaucitron.

2.5. Gestion du Wi-Fi hôtelier

Le traitement de gestion du Wi-Fi hôtelier vise à fournir un accès Internet aux clients durant leur séjour, à administrer les systèmes informatiques, à remédier aux dysfonctionnements techniques et à prévenir les menaces à la sécurité publique conformément aux obligations légales.

Ces traitements reposent sur le consentement des clients pour l'utilisation du service Wi-Fi, ainsi que sur l'obligation légale imposée par l'article L.34 du Code des Postes et Communications Électroniques, qui impose la conservation des données de connexion pour mise à disposition des autorités compétentes en cas de réquisition judiciaire.

Les données sont accessibles à l'équipe IT et infrastructure, aux prestataires de maintenance informatique, ainsi qu'aux autorités compétentes sur demande légale.

2.6. Gestion du personnel et candidatures

Le traitement de gestion du personnel et des candidatures a pour finalité le recrutement de nouveaux collaborateurs, l'administration du personnel en poste (gestion des contrats, horaires, congés), le calcul et versement de la paie, le respect des obligations sociales et légales (déclarations URSSAF, médecine du travail), ainsi que la gestion des formations.

Ces traitements reposent sur l'exécution du contrat de travail, les obligations légales imposées par le Code du travail et les organismes sociaux (URSSAF, caisses de retraite), ainsi que l'intérêt légitime de l'employeur pour la gestion administrative et l'évaluation des collaborateurs.

Les données sont accessibles à la direction RH, aux services administratifs, aux organismes sociaux (URSSAF, caisses de retraite et assurance), aux prestataires de systèmes RH (SIRH/AES, paie) et au cabinet d'audit comptable.

2.7. Vidéoprotection

Le traitement de vidéoprotection a pour finalité la sécurité des biens et des personnes au sein des établissements hôteliers, la prévention des menaces à la sécurité (vols, dégradations, agressions) et la documentation d'incidents éventuels.

Ce traitement repose sur l'intérêt légitime de B&B Hotels pour assurer la sécurité de ses clients, de son personnel et de ses biens.

Les images vidéo sont enregistrées dans les espaces communs (hall d'accueil, couloirs, entrées) et sont accessibles uniquement à la direction et à la gérance de l'hôtel, aux forces

de l'ordre en cas de réquisition, ainsi qu'à l'assureur en cas d'incident nécessitant une déclaration de sinistre.

2.8. Fiches individuelles de police

Le traitement des fiches individuelles de police vise à établir les fiches obligatoires pour les clients étrangers séjournant dans l'hôtel, à répondre aux réquisitions judiciaires et aux demandes de renseignement des services des douanes.

Ce traitement repose sur une obligation légale définie par la Délibération CNIL 2016-176 et l'article R.611-42 du Code de l'Entrée et du Séjour des Étrangers et du Droit d'Asile (CESEDA).

Les fiches sont transmises aux services de police, à la gendarmerie nationale et aux douanes selon les modalités légales.

2.9. Gestion des contentieux et sinistres

Le traitement de gestion des contentieux et sinistres a pour finalité le traitement des dossiers sinistres auprès de l'assureur, la gestion du précontentieux (négociations, médiations) et la défense en cas de contentieux pénaux ou civils devant les juridictions compétentes.

Ce traitement repose sur l'intérêt légitime de B&B Hotels pour assurer sa défense en justice, ainsi que sur l'obligation légale de conserver les preuves nécessaires au respect des délais de prescription.

Les données sont accessibles à la direction, à l'assureur, aux avocats, aux experts-comptables et aux tribunaux compétents.

2.10. Classification de données traitées

Catégories de données	Exemples	Durée de conservation
Identité	Civilité, nom, prénom, date/lieu de naissance, nationalité, sexe,	Variable selon traitement : durée du contrat, 5 ans après

Catégories de données	Exemples	Durée de conservation
	numéro de salarié, numéro de document d'identité	départ (RH), 6 mois (police), 10 ans (fiscal)
Contact	Email, téléphone, adresse postale, code postal, pays, langue	Variable : durée du contrat, 3 ans après dernier contact (CRM/Marketing), 5 ans (RH), 10 ans (fiscal)
Données de réservation	Identifiant client, dates de séjour, numéro de chambre, code d'accès, hôtel, numéro de contrat, occupants	Durée du contrat + 5 ans archivage (contentieux)
Données sensibles (handicap, allergies, motif)	Handicap (demande chambre adaptée), motif du séjour, allergies, besoins spécifiques, demandes particulières	Uniquement durant le séjour (puis suppression), sauf incident (5 ans)
Données bancaires sensibles	Numéro de carte bancaire (tokenisé par Adyen), date de validité, cryptogramme, RIB/IBAN	15 mois après débit (cartes), 10 ans exercice (fiscal), 5 ans (RH)
Données financières	Montants facturés, mode de paiement, identifiants de transaction, références facture, montants de paie, variables de paie	10 ans à compter de la clôture de l'exercice
Données de paiement	Montant de réservation, garantie de paiement, horodatage, numéro terminal	Jusqu'au paiement effectif + 5 ans (contentieux)

Catégories de données	Exemples	Durée de conservation
Historique client	Historique des réservations, hôtels visités, préférences de chambre, sollicitations auprès de l'assistance	3 ans après dernier contact (CRM), 5 ans (contentieux)
Données de réclamations	Objet, circonstances, date, lieu, échanges avec services, justificatifs	5 ans en archivage (délai probatoire)
Données de satisfaction	Réponses aux enquêtes, enregistrements audio (borne d'assistance)	1 mois (enregistrements); 2 ans après publication de l'avis
Données de fidélité	Numéro de membre, points cumulés, avantages obtenus	Toute la durée du contrat d'adhésion
Avis clients	Commentaires publiés sur Facebook, Instagram, LinkedIn	2 ans après publication
Données de navigation/Cookies	Adresse IP, identifiant cookie, comportement sur site, préférences, historique de clics	IP: 3 mois; Cookies: 6 mois; Traceurs: 25 mois maximum
Données marketing	Historique d'ouverture d'emails, clics, offres consultées, interactions réseaux sociaux	3 ans à compter du dernier contact ou retrait du consentement
Identifiants de retargeting	Identifiants Google Ads, Meta, Criteo, Dynatrace	25 mois maximum (selon durée de vie du traceur)
Données de connexion Wi-Fi	Logs de connexion, URL, date, heure, adresse IP, identifiant	1 an (administration); 24 heures (maintien connexion); selon

Catégories de données	Exemples	Durée de conservation
	terminal, identifiant de connexion	prescription (obligation légale)
Données de performance réseau	Données de performance réseau, informations techniques	24 heures à 1 an selon contexte
Données contractuelles & RH	Contrat de travail, poste, temps de travail, évaluations, entretiens, formations	5 ans après départ du salarié
Données de santé (travail)	Aptitude médicale, accidents du travail, handicap déclaré pour aménagements	5 ans après départ du salarié
Candidatures	CV, lettre de motivation, notes d'entretien	2 ans après dernier contact (non-retenus)
Images vidéo	Enregistrements des espaces communs et entrées de l'hôtel, identification des personnes en cas d'incident	Quelques jours à 1 mois (normal); 5 ans après l'incident (contentieux)
Données de séjour (police)	Dates de séjour, hôtel concerné, numéro de chambre	6 mois à compter de l'établissement de la fiche
Données de contentieux	Circonstances, date, lieu, photos, vidéos, échanges avec assurance/avocats, jugements, ordonnances	Jusqu'à décision définitive + 10 ans

3. Supports matériels et techniques des traitements

3.1. Matériels informatiques

B&B Hotels s'appuie sur une infrastructure matérielle diversifiée pour assurer le traitement et la sécurité de ses données personnelles.

Les **serveurs de production et de sauvegarde** sont hébergés chez Datacampus (France), garantissant une redondance et une disponibilité des systèmes sans externalisation hors de l'Union Européenne.

Les **ordinateurs de réception** présents dans chaque hôtel permettent au personnel d'accéder au système de gestion hôtelière (PMS) pour enregistrer les réservations et gérer les clients.

Des **ordinateurs portables** sont distribués aux équipes de direction, commerciale et IT pour leur permettre d'accéder aux systèmes depuis différents lieux (bureaux de Brest et Paris, hôtels du réseau).

Les **terminaux de paiement Adyen** installés à la réception traitent les données de paiement de manière sécurisée via tokenisation.

Un **équipement de téléphonie** (centrale téléphonique et postes de réception) permet la gestion des appels clients, avec possibilité d'enregistrement optionnel sur la borne d'assistance pour assurance qualité.

Des **disques durs externes et périphériques de stockage** sont utilisés pour les sauvegardes régulières et l'archivage sécurisé des données (contrats, documents RH, factures).

Enfin, les **équipements réseau** (routeurs, pare-feu, commutateurs) assurent l'interconnexion sécurisée entre les différents sites et la protection du réseau interne.

3.3. Logiciels et systèmes

Le traitement des données repose sur plusieurs applications informatiques critiques. Le **système de gestion hôtelière (PMS)** constitue le cœur du système d'information. B&B Hotels utilise un système propriétaire hébergé chez Datacampus, qui centralise la gestion des réservations, des clients, des services et de la facturation. Le **CRM Salesforce** assure la gestion de la relation client et permet le suivi des réclamations et interactions ; ce système est accessible depuis les États-Unis selon les Clauses Contractuelles Types (CCT).

Les **systèmes d'exploitation** (Windows Server, Linux) sur les serveurs et postes de travail fournissent la base technique pour exécuter les applications métier. Un **logiciel de**

facturation et comptabilité (Sinao pour le secteur hôtelier) produit les factures et assure la tenue des registres comptables conformément aux obligations légales, avec gestion de la TVA adaptée aux prestations d'hébergement. Le système **SIRH/AES** (Système d'Information des Ressources Humaines) gère l'administration du personnel (contrats, horaires, congés), tandis qu'un **logiciel de paie (Paie@web)** calcule et traite les rémunérations, prélèvements obligatoires et déclarations sociales (URSSAF, caisses de retraite).

Des **outils de chiffrement et d'authentification** (VPN, certificats SSL/TLS, authentification multi-facteurs) protègent l'accès aux systèmes sensibles et les échanges de données.

Un **antivirus et pare-feu de dernière génération** défendent contre les menaces malveillantes et les tentatives d'intrusion. L'outil **Tarteaucitron** gère les consentements relatifs aux cookies et traceurs avec une validité de 6 mois. Des outils de **monitoring et de supervision** (**Dynatrace** pour la performance applicative et **Akamai Bot Manager** pour la sécurité applicative) assurent la détection des anomalies et des attaques, optimisent les performances et maintiennent la disponibilité des services en ligne.

3.3. Canaux de communication

Les données transitent par plusieurs canaux de communication logiques et physiques. La connexion **Internet et fibre optique** assure la communication externe de l'entreprise avec ses clients et partenaires. Un **réseau Wi-Fi hôtelier** sécurisé (WPA2/WPA3) permet aux clients d'accéder à Internet durant leur séjour, soumis aux obligations légales de conservation des logs. Le **réseau interne filaire (LAN)** sécurisé interconnecte les serveurs, ordinateurs de réception et bureaux administratifs avec authentification et chiffrement.

Les **systèmes de téléphonie** (appels, enregistrements optionnels sur borne d'assistance) facilitent les communications avec les clients pour les demandes et réclamations.

Les **emails internes et externes** assurent la communication administrative et commerciale. Des **courriers électroniques sécurisés** (utilisant le chiffrement) sont employés pour les échanges sensibles avec partenaires et prestataires.

Les **coursiers** (services de transport physiques) acheminent les documents papier archivés et contrats entre les sites (Brest, Paris, hôtels du réseau). Les **échanges verbaux** directs avec clients et partenaires complètent les canaux formels.

3.4. Supports papier

Bien que B&B Hotels s'oriente vers la dématérialisation, certaines données demeurent sur supports papier. Les **fiches de réservation imprimées** peuvent être générées à titre conservatoire pour certains clients. Les **contrats et devis** sont conservés en format papier selon les durées légales de conservation (10 ans pour documents fiscaux, 5 ans pour

contentieux). Les **fiches individuelles de police** (pour étrangers) sont obligatoirement établies en format papier et conservées 6 mois.

Les **justificatifs de paiement et factures** imprimés ou photocopiés constituent les preuves comptables archivées 10 ans. Les **documents RH imprimés** (contrats de travail, évaluations, formations) sont conservés 5 ans après départ du salarié. Des **registres et cahiers de maintenance** documentent les interventions informatiques et matérielles pour traçabilité. Les **archives légales et comptables** imprimées (livres comptables, déclarations fiscales, rapports d'audit) sont conservées selon les délais légaux obligatoires.

3.5. Locaux et installations physiques

Les données sont stockées et traitées dans plusieurs environnements physiques sécurisés. Les **salles serveurs Datacampus** (France) constituent l'infrastructure principale d'hébergement. Ces locaux bénéficient d'une sécurité physique renforcée (contrôle d'accès, vidéosurveillance), d'une climatisation régulée, d'une redondance électrique (alimentation sans interruption, groupes électrogènes) et d'une isolation contre les risques d'incendie.

Les **bureaux administratifs** (271 rue du Général Paulet, Brest, et 9 boulevard Romain Rolland, Paris) accueillent les équipes RH, financière, commerciale et IT. Chaque bureau est équipé d'ordinateurs, d'archives sécurisées et d'imprimantes multifonctions.

Les **réceptions des hôtels** du réseau disposent de postes de réception avec accès au PMS, de terminaux de paiement Adyen et de systèmes téléphoniques locaux.

Des **locaux de stockage sécurisés** (armoires de rangement avec serrure, coffres-forts) conservent les documents papier sensibles (contrats archivés, disques durs de sauvegarde), avec accès limité aux personnes habilitées. Les **locaux informatiques** (baies de commutation réseau, équipements de sécurité comme pare-feu et routeurs) assurent la gestion technique du réseau et sa protection contre les attaques externes.

I. Question N°3 : Mises à jour régulières

II. Appréciation des risques liés aux traitements

L'analyse des risques liés aux traitements de données personnelles chez B&B Hotels vise à identifier, évaluer et hiérarchiser les menaces pesant sur la confidentialité, l'intégrité et la disponibilité des informations traitées. Cette appréciation s'appuie sur la méthodologie recommandée par la CNIL dans son guide pratique de sécurité des données personnelles, en examinant les sources de risques (menaces et vulnérabilités),

leurs probabilités d'occurrence et leurs impacts potentiels sur les clients, l'entreprise et ses partenaires. L'objectif est d'identifier les actions prioritaires de renforcement de la sécurité pour assurer la conformité RGPD et protéger les données traitées au sein de B&B Hotels.

Tableau d'analyse des risques

(Voir annexe)

III. Mise en œuvre de mesures de sécurité

L'analyse des risques menée en Partie II a identifié plusieurs vulnérabilités critiques et élevées chez B&B Hotels. Cette partie propose des mesures de sécurité concrètes et contextualisées, organisées selon les 17 fiches du guide CNIL. Pour chaque fiche, des mesures spécifiques sont définies pour réduire soit la probabilité d'occurrence (diminuer la vraisemblance), soit l'impact potentiel (abaisser la gravité) des risques identifiés. L'objectif est de passer les risques critiques et élevés à un niveau acceptable (moyen ou faible) tout en maintenant les risques déjà maîtrisés.

1. Fiche 1 : Sensibiliser et former les utilisateurs

Risques ciblés : Accès non autorisé au PMS, phishing des agents de réception, violation du Wi-Fi, fuite de données RH

Mesures actuelles :

- Aucune formation formalisée identifiée dans le registre de traitement

Lacunes identifiées :

- Manque de sensibilisation du personnel hôtelier aux risques de phishing
- Absence de charte informatique documentée
- Pas de formation RGPD régulière pour les nouveaux salariés
- Personnel non conscient des bonnes pratiques de sécurité (mots de passe, partage de données)

Mesures supplémentaires recommandées :

a) **Formation initiale RGPD et sécurité**

- Formation obligatoire pour tous les nouveaux employés (réception, administratif, IT)
- Contenu : respect RGPD, sécurité des données, bonnes pratiques informatiques
- Durée : 2 heures minimum
- Validation : signature d'une attestation

b) Campagnes de sensibilisation régulières

- Campagnes mensuelles anti-phishing : envoi de faux emails pour test
- Affiches en espaces communs sur protection des données
- Newsletter trimestrielle sur sécurité informatique
- Sessions interactives (30 min) tous les trimestres

c) Charte informatique formalisée

- Document signé par chaque employé
- Rappel des droits et obligations (confidentialité, sécurité, responsabilité)
- Sanctions en cas de non-respect
- Mise à jour annuelle

d) Formation spécialisée par rôle

- Personnel de réception : sécurisation des données clients, phishing, accès PMS
- Service RH : confidentialité des données salariés, gestion des habilitations
- Service IT : sécurité serveurs, gestion des incidents, sauvegarde
- Direction commerciale : RGPD dans les campagnes marketing, consentement

Impact attendu :

- Réduction de la **probabilité** des accès non autorisés (Moyen → Faible)
- Réduction de la **probabilité** du phishing (Moyen → Faible-Moyen)
- Amélioration de la culture de sécurité générale

2. Fiche 2 : Gérer les habilitations et accès

Risques ciblés : Accès non autorisé au PMS, données RH exposées, accès CRM non contrôlé, modification de paie

Mesures actuelles :

- Accès au PMS par authentification basique (login/mot de passe)
- Accès SIRH/AES et Paie@web non formellement documentés
- Accès Salesforce par SSO (Single Sign-On)

Lacunes identifiées :

- Habilitations trop larges (tout le personnel peut accéder à certaines données)
- Absence de matrice de contrôle d'accès (RACI/ACL)
- Pas de révision régulière des droits
- Suppression d'accès non systématisée lors des départs
- Absence de ségrégation des tâches (qui crée/valide/paye ?)

Mesures supplémentaires recommandées :

a) Mise en place d'une matrice de contrôle d'accès (ACL)

- Par rôle : réceptionniste, gestionnaire administratif, direction, RH, IT
- Par système : PMS, CRM Salesforce, SIRH/AES, Sinao, Paie@web, serveurs, Wi-Fi
- Par données : données clients, données bancaires, données RH, archives
- Principe du besoin de connaître (least privilege)

b) Gestion des accès administratifs

- Accès administrateur réservé à IT uniquement (liste restreinte)
- Comptes administrateur séparés du compte personnel
- Audit des actions administrateur (logs)
- Renouvellement du mot de passe admin trimestriel

c) Ségrégation des tâches

- Créateur de données ≠ Approbateur ≠ Auditeur
- Exemple paie : gestionnaire crée, responsable RH valide, directeur approuve

- Mise en place de workflows d'approbation dans SIRH/AES et Sinao

d) Révision trimestrielle des droits

- Audit des accès tous les 3 mois par direction IT
- Suppression des accès superflus
- Validation par manager de chaque employé
- Documentation de la révision

e) Processus de déprovisionnement

- Lors de départ : suppression des accès dans les 24h
- Reprise des identifiants et badges
- Audit des données accédées par l'employé (détection de vol)
- Archivage sécurisé du compte (6 mois avant suppression définitive)

Impact attendu :

- Réduction de la **probabilité** d'accès non autorisé (Moyen → Faible)
- Réduction de la **probabilité** de modification de données (Moyen → Faible)
- Amélioration de la conformité RGPD et de l'audit

3. Fiche 3 : Authentifier les utilisateurs

Risques ciblés : Accès non autorisé au PMS/CRM/RH, usurpation d'identité, vol de données

Mesures actuelles :

- Authentification par login/mot de passe sur PMS
- Salesforce dispose d'un SSO
- Pas de MFA (Multi-Factor Authentication) généralisée

Lacunes identifiées :

- Mots de passe faibles (pas d'exigence de complexité documentée)
- Pas de MFA pour accès sensibles (données bancaires, RH)

- Authentification non chiffrée sur certains accès
- Pas de verrouillage après tentatives échouées

Mesures supplémentaires recommandées :

a) Politique de mots de passe robustes

- Longueur minimale : 12 caractères
- Caractères requis : majuscule, minuscule, chiffre, caractère spécial
- Renouvellement : tous les 90 jours
- Historique : derniers 5 mots de passe interdits
- Verrouillage compte après 5 tentatives échouées (30 min)

b) Authentification Multi-Facteurs (MFA)

- MFA obligatoire pour : PMS, Salesforce, SIRH/AES, Sinao, Paie@web, serveurs, archives
- Type MFA : application d'authentification (Google Authenticator, Microsoft Authenticator) ou SMS
- Préférer application > SMS pour sécurité accrue
- Codes de secours générés et archivés sécurièrément

c) Authentification chiffrée

- Protocoles sécurisés : HTTPS (TLS 1.2+), LDAP sécurisé (LDAPS)
- Certificats SSL/TLS à jour (renouvellement annuel)
- Validation de certificats côté client

d) Gestion des sessions

- Timeout d'inactivité : 5 minutes pour données sensibles, 30 minutes pour autres
- Session unique par utilisateur (pas de partage de session)
- Déconnexion automatique en cas de fermeture navigateur
- Logs de connexion/déconnexion

e) Authentification pour accès distants (VPN)

- VPN obligatoire pour accès depuis l'extérieur

- VPN avec MFA
- Chiffrement fort (AES-256)

Impact attendu :

- Réduction de la **probabilité** d'accès non autorisé (Élevée → Moyen)
- Réduction de la **probabilité** d'usurpation d'identité (Moyen → Faible)
- Amélioration du contrôle d'accès général.

4. Fiche 4 : Tracer les opérations et gérer les incidents

Risques ciblés : Accès non autorisé, fuite de données, modification non désirée, violation de données

Mesures actuelles :

- Logs de connexion possibles sur PMS (à vérifier)
- Aucun système de monitoring centralisé identifié

Lacunes identifiées :

- Absence de traçabilité centralisée des opérations
- Pas de monitoring en temps réel des accès sensibles
- Absence de plan de réponse aux incidents
- Pas de procédure de notification CNIL

Mesures supplémentaires recommandées :

a) Système de logging centralisé

- Logs de tous les accès aux données sensibles (bancaires, RH, réservations)
- Logs de modifications de données (qui, quand, avant/après)
- Logs de Salesforce, PMS, SIRH/AES, Sinao
- Conservation des logs : minimum 1 an
- Chiffrement et protection des logs contre modification

b) Monitoring et alertes en temps réel

- Monitoring Dynatrace pour anomalies d'accès
- Alertes sur : accès multiples échoués, accès depuis IP inhabituelle, modifications massives
- Notification automatique à IT en cas d'alerte
- Tableau de bord de sécurité (dashboard)

c) **Plan de gestion des incidents**

- Document formalisé + procédure opérationnelle
- Étapes : détection → confinement → investigation → notification → correction
- Équipe d'intervention (IT, DPO, direction)
- Exercices de simulation (annuel minimum)

d) **Notification CNIL et clients en cas de violation**

- Obligation légale : notification dans les 72h après découverte
- Procédure de notification formalisée
- Modèles de lettres aux clients affectés
- Communication à l'assurance

e) **Audit des opérations**

- Audit mensuel des accès sensibles
- Rapport d'anomalies
- Analyse des tentatives de contournement

Impact attendu :

- Amélioration de la **détection** des incidents (temps de réaction réduit)
- Amélioration de la **réactivité** en cas de violation (68% → <72h)
- Meilleure **conformité RGPD**

5. Fiche 5 : Sécuriser les postes de travail

Risques ciblés : Malware, vol de données, accès physique non autorisé

Mesures actuelles :

- Antivirus et pare-feu mentionnés dans infrastructure
- État des postes de réception non documenté

Lacunes identifiées :

- Postes de réception non verrouillés (écran de veille manquant)
- Pas d'exigence de mises à jour régulières
- Absence de politique BYOD claire
- Périphériques USB potentiellement actifs

Mesures supplémentaires recommandées :**a) Durcissement des postes de travail**

- Systèmes d'exploitation à jour (Windows Server 2022+, patchs mensuels)
- Antivirus/antimalware tiers (ex : Kaspersky, Sophos)
- Mise à jour automatique activée
- Pare-feu personnel activé
- Logiciels inutiles désinstallés

b) Écran de veille et verrouillage

- Écran de veille obligatoire après 5 min d'inactivité
- Verrouillage auto (Ctrl+Alt+Del)
- Mot de passe requis au réveil
- Mise en place sur **tous les postes** (y compris réception)

c) Gestion des périphériques

- Ports USB désactivés par défaut
- USB autorisés uniquement pour IT avec demande écrite
- Périphériques USB avec chiffrement obligatoire
- Audit régulier des USB utilisés

d) Outils de gestion centralisée

- MDM (Mobile Device Management) pour portables
- Gestion de configuration centralisée (Group Policy)
- Télémétrie de sécurité
- Capacité de verrouillage/effacement à distance (en cas de perte)

e) Chiffrement du disque dur

- BitLocker (Windows) ou LUKS (Linux) pour disques durs
- Particulièrement pour : ordinateurs portables, serveurs
- Clés de chiffrement stockées sécurièrement

Impact attendu :

- Réduction de la **probabilité** de malware (Moyen → Faible)
- Réduction de la **probabilité** de vol/perte de données (Moyen → Faible)

6. Fiche 6 : Sécuriser l'informatique mobile

Risques ciblés : Perte d'ordinateurs portables, accès non autorisé depuis l'extérieur

Mesures actuelles :

- Ordinateurs portables utilisés par direction/commercial
- Accès possibles via VPN non documenté

Lacunes identifiées :

- Pas de chiffrement de disque documenté pour portables
- Politique de VPN non formalisée
- Pas de gestion de perte/vol de portables

Mesures supplémentaires recommandées :

a) Chiffrement des portables

- BitLocker ou équivalent obligatoire
- Clés de chiffrement archivées (en cas de perte)

- Validation lors de l'attribution

b) Gestion des accès distants

- VPN obligatoire pour accès aux systèmes critiques
- VPN avec MFA
- Adresse IP restreinte si possible (accès depuis villes principales B&B)
- Enregistrement des accès VPN

c) Procédure de perte/vol

- Signalement immédiat à IT
- Verrouillage/effacement à distance via MDM
- Audit des données accédées
- Rapport à l'assurance

d) Sécurité physique des portables

- Utilisation de câbles antivol en déplacements
- Jamais laisser sans surveillance
- Écran de confidentialité (anti-regards)
- Transport sécurisé (sacoche blindée)

Impact attendu :

- Réduction de l'**impact** en cas de perte de portable (Critical → Moyen)

7. Fiche 7 : Protéger le réseau informatique interne

Risques ciblés : Interception Wi-Fi, accès non autorisé au réseau, exfiltration de données

Mesures actuelles :

- Wi-Fi WPA2 mentionné
- Segmentation réseau partiellement existante (données Datacampus)

Lacunes identifiées :

- Wi-Fi hôtelier WPA2 (non WPA3) potentiellement vulnérable

- Absence de segmentation formelle entre réseaux (clients / administratif / RH)
- Absence de DMZ pour plateformes externes
- Pas de filtrage d'URLs malveillantes documenté

Mesures supplémentaires recommandées :

a) Upgrade Wi-Fi hôtelier

- Migration de WPA2 à **WPA3** (sécurité renforcée)
- Changement de mot de passe Wi-Fi régulier (annuel)
- Réseau Wi-Fi clients physiquement séparé du réseau administratif

b) Segmentation du réseau (VLAN)

- VLAN Clients : Wi-Fi publique (pas accès données internes)
- VLAN Administratif : PMS, gestion administrative
- VLAN RH : données sensibles salariés (accès restreint)
- VLAN Serveurs : Datacampus, backups
- Pare-feu entre VLAN

c) DMZ pour services externes

- Plateforme de réservation en DMZ
- Isolée du réseau interne
- Accès autorisé au PMS via pare-feu uniquement

d) Filtrage et sécurité réseau

- Pare-feu applicatif Web (WAF)
- Filtrage d'URLs malveillantes (blacklist)
- Anti-spam et anti-phishing au niveau réseau
- Détection d'intrusion (IDS) avec alertes

e) VPN pour accès distants

- VPN avec chiffrement AES-256
- MFA pour VPN

- Split tunneling désactivé (tout trafic via VPN)

Impact attendu :

- Réduction de la **probabilité** d'interception Wi-Fi (Élevée → Moyen-Faible)
- Réduction de la **probabilité** d'accès non autorisé (Moyen → Faible)
- Meilleure isolation et protection des données sensibles

8. Fiche 8 : Sécuriser les serveurs

Risques ciblés : Perte de données, accès non autorisé aux serveurs, indisponibilité

Mesures actuelles :

- Serveurs hébergés Datacampus (France)
- Redondance et résilience mentionnées

Lacunes identifiées :

- Contrôle d'accès physique non détaillé
- Mises à jour serveurs non formalisées
- Monitoring insuffisamment documenté
- Gestion des clés de chiffrement insuffisante

Mesures supplémentaires recommandées :

a) Durcissement des serveurs

- Systèmes d'exploitation à jour (Windows Server 2022+, patches mensuels)
- Désactivation de services inutiles
- Configuration firewall restreinte
- Principe du moindre privilège pour comptes serveurs

b) Mises à jour et correctifs réguliers

- Calendrier de patches défini (2ème mardi du mois)
- Environnement de test pour validation

- Documentation des changements
- Rollback plan en cas de problème

c) **Monitoring 24/7**

- Dynatrace : performance, disponibilité, sécurité applicative
- Monitoring des ressources (CPU, RAM, disque, réseau)
- Alertes configurées sur seuils critiques
- Escalade automatique à IT en cas d'incident

d) **Contrôle d'accès physique Datacampus**

- Badge/authentification biométrique
- Registre de tous les accès
- Caméras de surveillance dans salles serveurs
- Contrôle annuel des accès (révocation si départ)
- Visite d'inspections semestrielles

e) **Gestion des clés de chiffrement**

- Clés stockées dans coffre-fort sécurisé (HSM - Hardware Security Module)
- Séparation : clés de stockage vs clés de transport
- Rotation des clés tous les 2 ans
- Archivage sécurisé des anciennes clés

f) **Sauvegarde des configurations**

- Configuration serveurs versionnées et archivées
- Capacité de restauration en cas de compromission

Impact attendu :

- Amélioration de la **disponibilité** des systèmes
- Réduction de la **probabilité** d'accès non autorisé (Moyen → Faible)
- Meilleure détection des incidents

9. Fiche 9 : Sécuriser les sites web et applications

Risques ciblés : Injection SQL, vol de données réservations, usurpation de clients, indisponibilité plateforme

Mesures actuelles :

- Plateforme HTTPS avec certificats SSL/TLS
- Akamai Bot Manager pour protection DDoS

Lacunes identifiées :

- Tests de sécurité web insuffisamment documentés
- Absence de Web Application Firewall (WAF) explicite
- Pas de test de pénétration réguliers
- Gestion des vulnérabilités non formalisée

Mesures supplémentaires recommandées :

a) Hardening de la plateforme web

- Mise à jour des frameworks (PHP, Node.js, etc.)
- Désactivation des services/ports inutiles
- Configuration sécurisée des en-têtes HTTP (CSP, X-Frame-Options, etc.)
- Suppression des pages/fichiers de debugging

b) Web Application Firewall (WAF)

- WAF Akamai ou équivalent en place
- Règles configurées : anti-injection SQL, anti-XSS, anti-traversée
- Logs des attaques bloquées
- Mise à jour des règles hebdomadaire

c) Validation des entrées et sorties

- Validation stricte de tous les inputs (réservations, paiements)
- Sanitization des données affichées
- Paramètres de requête vérifiés côté serveur

- Absence d'erreurs révélant l'architecture

d) Certificats SSL/TLS

- Certificats à jour et valides (renouvellement automatique)
- TLS 1.2 minimum (idéalement TLS 1.3)
- Certificats wildcard ou SAN pour domaines
- HSTS activé (force HTTPS)

e) Tests de sécurité réguliers

- Scan de vulnérabilités mensuels (automatisé)
- Test de pénétration annuel (entreprise externe)
- Bug bounty program (optionnel mais recommandé)
- Audit du code source annuel

f) Gestion des dépendances

- Inventaire des librairies/composants utilisés
- Monitoring des CVE (Common Vulnerabilities)
- Mise à jour proactive des dépendances vulnérables

Impact attendu :

- Réduction de la **probabilité** d'injection SQL (Moyen → Faible)
- Réduction de la **probabilité** de vol de données (Moyen → Faible-Moyen)
- Meilleure résilience face aux attaques DDoS

10. Fiche 10 : Sauvegarder et prévoir la continuité d'activité

Risques ciblés : Perte de données, indisponibilité prolongée, ransomware

Mesures actuelles :

- Sauvegardes probablement effectuées par Datacampus
- Redondance mentionnée

Lacunes identifiées :

- RTO/RPO (Recovery Time Objective / Recovery Point Objective) non documentés
- Tests de récupération non formalisés
- Plan de continuité incomplet
- Chiffrement des sauvegardes non confirmé

Mesures supplémentaires recommandées :

a) Stratégie de sauvegarde 3-2-1

- 3 copies des données : originale + 2 sauvegardes
- 2 supports différents : disques + bande magnétique ou cloud
- 1 copie hors site : archive chez Datacampus ou cloud sécurisé
- **Fréquence** : PMS quotidien, données RH 2x/semaine, archives mensuelles

b) Chiffrement des sauvegardes

- Chiffrement AES-256 des fichiers de sauvegarde
- Clés de déchiffrement archivées sécurièrément
- Tests de déchiffrement réguliers

c) Définition de RTO/RPO

- **PMS (Critique)** : RTO = 2h, RPO = 1h
- **Données RH (Critique)** : RTO = 4h, RPO = 4h
- **Données marketing (Moyen)** : RTO = 1 jour, RPO = 1 jour
- **Archives (Faible)** : RTO = 1 semaine, RPO = 1 mois

d) Tests de récupération réguliers

- Test de récupération annuel (minimum) pour chaque système critique
- Simulation complète (restauration et validation des données)
- Documentation des temps et problèmes rencontrés
- Plan d'amélioration basé sur les tests

e) Plan de continuité d'activité (PCA)

- Document formalisé : procédures, contacts, escalade
- Site de secours identifié (en cas d'indisponibilité Datacampus)
- Procédures de basculement documentées
- Exercice de crise annuel

f) **Gestion des bandes magnétiques**

- Bandes archivées dans endroit sécurisé (climat contrôlé)
- Inventaire et traçabilité des bandes
- Tests de lisibilité tous les 5 ans
- Destruction sécurisée en fin de vie

Impact attendu :

- Réduction de l'**impact** d'une perte de données (Critique → Moyen-Faible)
- Réduction du **temps d'indisponibilité** en cas d'incident
- Meilleure conformité aux obligations légales

11. Fiche 11 : Archiver de manière sécurisée

Risques ciblés : Accès non autorisé aux archives, exposition de données anciennes

Mesures actuelles :

- Données archivées chez Datacampus (supposé sécurisé)
- Durées de conservation définies par traitement

Lacunes identifiées :

- Chiffrement des archives non confirmé
- Contrôle d'accès aux archives insuffisant
- Destruction de données non formalisée
- Absence de registre d'archivage

Mesures supplémentaires recommandées :

a) Chiffrement des archives

- Chiffrement AES-256 pour toutes les archives
- Clés archivées sécurièrément (distinctes des données)
- Validation du chiffrement avant archivage

b) Contrôle d'accès aux archives

- Accès restreint aux archives (IT + direction RH pour données RH)
- Demande écrite obligatoire pour accès archive
- Audit des accès aux archives
- Suppression automatique des droits après utilisation

c) Registre d'archivage

- Document centralisé listant toutes les archives
- Données, dates, location, état du chiffrement
- Justification légale de conservation
- Date de destruction prévue

d) Destruction sécurisée

- Disques durs : broyage certifié (ADISA DS-3)
- Documents papier : incinération
- Bandes magnétiques : démagnétisation
- Certificat de destruction requis
- Audit de destruction

e) Stockage physique sécurisé

- Local dédié aux archives (accès restreint)
- Climatisation et prévention incendie
- Inventaire annuel
- Assurance couvrant destruction accidentelle

Impact attendu :

- Réduction de la **probabilité** d'accès non autorisé (Faible → Très faible)
- Conformité RGPD d'effacement de données

12. Fiches 12-14 : Développement, maintenance, sous-traitance, échanges externes

Risques ciblés : Vulnérabilités dans code, introduction de malware, fuite via sous-traitants

Mesures actuelles :

- Contrats de traitement supposément en place avec sous-traitants
- Maintenance IT effectuée (niveau insuffisant documenté)

Lacunes identifiées :

- Clauses de sécurité insuffisantes dans contrats
- Audit des sous-traitants non formalisé (particulièrement Salesforce CCT, Adyen)
- Procédures de maintenance non documentées
- Échanges de données non sécurisés

Mesures supplémentaires recommandées :

a) Contrats avec clauses de sécurité renforcées

- **Salesforce** : CCT à jour, vérification annuelle de conformité
- **Adyen** : conformité PCI DSS, audit annuel
- **Datacampus** : SLA de disponibilité et sécurité, droit d'audit
- **OTA** (Booking, Expedia) : limitation données, notification incidents
- **Clauses obligatoires** : notification incidents <24h, droit d'audit, destruction données fin contrat

b) Audit annuel des sous-traitants

- Vérification des certifications (ISO 27001, SOC 2, PCI DSS)
- Audit de conformité RGPD
- Contrôle des accès et sécurité physique

- Validation des mesures de sécurité

c) Procédures de maintenance formalisées

- Demande écrite avant intervention
- Maintenance en heures de bureau sauf urgence
- Logging de toutes les actions maintenance
- Rapport d'intervention documenté
- MFA pour accès maintenance

d) Sécurisation des échanges de données

- Échanges chiffrés (SFTP, VPN, email chiffré)
- Identification vérifiée du correspondant
- Justification business pour chaque échange
- Audit des échanges

Impact attendu :

- Réduction de la **probabilité** de fuite via sous-traitants (Moyen → Faible)
- Amélioration de la **conformité** aux contrats

13. Fiche 15 : Protéger les locaux

Risques ciblés : Accès physique non autorisé aux serveurs et archives, vol de matériel

Mesures actuelles :

- Salles serveurs Datacampus mentionnées
- Vidéosurveillance à disposition

Lacunes identifiées :

- Contrôle d'accès physique insuffisant aux locaux sensibles
- Vidéosurveillance incomplète (Archives, salles IT)
- Registre d'accès non documenté

Mesures supplémentaires recommandées :

a) Contrôle d'accès physique

- Salles serveurs Datacampus : badge + authentification biométrique (empreinte)
- Bureau IT : accès via badge
- Archives papier : armoire verrouillée + badge pour local
- Bureaux RH : accès aux données sensibles restreint
- Registre signé de tous les accès (quand, qui, pourquoi)

b) Vidéosurveillance des zones sensibles

- Caméras dans salles serveurs Datacampus
- Caméras dans locaux archives
- Caméras dans hall réception (données sensibles manipulées)
- Enregistrements conservés 6 mois minimum
- Accès aux vidéos restreint (IT + direction)

c) Prévention du vol

- Inventaire annuel du matériel (serveurs, ordinateurs, disques durs)
- Asset tagging (identifiants uniques)
- Câbles antivol pour équipements
- Destruction des anciens équipements (via prestataire certifié)

d) Visite d'inspection

- Visite semestrielle des salles Datacampus
- Checklist de sécurité physique
- Rapport d'inspection signé

Impact attendu :

- Réduction de la **probabilité** d'accès physique non autorisé (Faible → Très faible)
- Détection plus rapide de tentatives d'intrusion

14. Fiche 16 : Chiffrer, hacher, signer les données

Risques ciblés : Vol de données bancaires, modification non autorisée de factures, fuite RH

Mesures actuelles :

- Tokenisation des données bancaires par Adyen mentionnée
- Certificats SSL/TLS pour plateforme web

Lacunes identifiées :

- Chiffrement des données sensibles au repos insuffisant
- Mots de passe non hachés (ou hachage faible)
- Gestion des clés de chiffrement insuffisante
- Signature numérique non utilisée pour documents importants*ç_

Mesures supplémentaires recommandées :

a) Chiffrement des données sensibles au repos

- Chiffrement AES-256 pour données bancaires (cartes, RIB)
- Chiffrement AES-256 pour données RH sensibles
- Chiffrement AES-256 pour données de réservation comportant données sensibles
- Clés d'archivage distinctes des clés de traitement

b) Chiffrement des données en transit

- TLS 1.2+ pour tous les échanges (web, API, VPN)
- Certificats SSL/TLS à jour
- Validation de certificats côté client

c) Hachage des mots de passe

- Fonction de hachage robuste : bcrypt, Argon2 (pas MD5 ou SHA-1)
- Salts générés aléatoirement
- Validation à la connexion

d) Gestion des clés de chiffrement

- Clés stockées dans HSM (Hardware Security Module)
- Clés de chiffrement séparées par domaine (données clients, RH, bancaires)
- Rotation des clés tous les 2 ans
- Archivage des anciennes clés pour déchiffrement futur
- Plan de récupération de clés (perte/vol)

e) Signature numérique pour documents importants

- Factures signées numériquement (certificat X.509)
- Contrats de travail signés électroniquement
- Rapports d'audit signés
- Validation de signature lors de consultations

f) Validation de l'intégrité des données

- Hachage des données critiques (bases de données)
- Vérification régulière de l'intégrité
- Alertes en cas de modification détectée

Impact attendu :

- Réduction de l'**impact** d'une fuite de données bancaires (Critique à Moyen)
- Conformité aux standards de sécurité (PCI DSS)
- Imputabilité documentaire renforcée

15. Fiche 17 : Evaluer le niveau de sécurité

Risques ciblés : Amélioration continue de la sécurité, détection des nouvelles vulnérabilités

Mesures actuelles :

- Registre de traitements existant
- Analyse des risques en cours

Lacunes identifiées :

- Absence d'audit de sécurité formel
- Tests de pénétration non réguliers
- AIPD (Analyse d'Impact) non systématisée
- Pas de tableau de bord de conformité RGPD

Mesures supplémentaires recommandées :

a) Audit de sécurité annuel

- Audit interne ou externe (préférer externe pour indépendance)
- Couverture complète : infrastructure, logiciels, processus, personnel
- Rapport d'audit avec recommandations prioritisées
- Plan d'actions correctrices

b) Tests de pénétration réguliers

- Test de pénétration annuel (entreprise spécialisée)
- Couverture : plateforme web, réseau interne, Wi-Fi hôtelier
- Rapport détaillé des vulnérabilités trouvées et exploitées
- Calendrier de correction défini

c) Analyse d'Impact Relative à la Protection des Données (AIPD/DPIA)

- DPIA pour tous les nouveaux traitements (avant déploiement)
- DPIA annuelle pour traitements existants (révision)
- DPIA en cas de changement significatif (nouveau sous-traitant, nouveau système)
- Documentation formalisée

d) Tableau de bord de conformité RGPD

- Métriques de sécurité : incidents, patchs, audits
- Métriques de conformité : droits exercés, AIPD, formations
- Tableau de bord automatisé mis à jour mensuellement
- Présentation trimestrielle à la direction

e) Gestion des vulnérabilités

- Inventaire des CVE (Common Vulnerabilities)
- Suivi des patches et corrections
- Validation de correction
- Rapport mensuel de posture de sécurité

f) Améliorations continues

- Comité de sécurité mensuel (IT + DPO + Direction)
- Revue des incidents et leçons apprises
- Identification des axes d'amélioration
- Plan d'action annuel

Impact attendu :

- Amélioration **continue** de la sécurité
- Détection plus rapide des nouvelles menaces
- Conformité RGPD renforcée et démontrable

Conclusion

Cette étude chez B&B Hotels révèle une infrastructure informatique structurée, mais des lacunes significatives dans la mise en œuvre des mesures de sécurité. L'analyse a identifié deux traitements à risque CRITIQUE (facturation/paiement et gestion RH) et trois à risque ÉLEVÉ (réservations, CRM, relations clients).

Le plan d'action proposé (17 fiches CNIL, 12 mesures prioritaires) permettra de réduire de 50 à 80% la probabilité des incidents de sécurité majeurs sur un horizon de 6 mois. Ces mesures sont réalistes, progressives et alignées avec les standards du secteur.

Trois facteurs critiques conditionneront le succès : l'engagement de la direction, l'allocation budgétaire, et l'implication du DPO dans un rôle de pilotage. Sans cela, B&B Hotels reste exposée à des sanctions RGPD pouvant atteindre 4% du chiffre d'affaires.

En conclusion, les recommandations sont claires et applicables. Il appartient désormais à la direction de les mettre en œuvre et à chaque collaborateur de s'approprier cette culture de sécurité.

Annexe

Traitement	Données sensibles	Menaces identifiées	Vulnérabilités	Probabilité	Impact	Criticité	Actions prioritaires
Gestion des réservations	Identité, contact, données sensibles (handicap, allergies)	Accès non autorisé au PMS, phishing des agents de réception, injection de code dans le formulaire de réservation	Authentification faible des postes de réception, absence de chiffrement bout-à-bout, manque de sensibilisation du personnel	Moyen	Élevé (usurpation d'identité, modification de réservations)	Élevée	Renforcer authentification, chiffrement SSL/TLS, formation personnel
Facturation et paiement	Données bancaires (carte, RIB), numéro de transaction	Interception des données de paiement, exploitation de vulnérabilités Adyen, usurpation de paiement, perte d'intégrité des factures	Tokenisation insuffisante, logs de transactions non chiffrés, absence de conformité PCI DSS complète	Élevée	Critique (fraude bancaire, violations RGPD majeures, sanctions financières)	Critique	Audit PCI DSS régulier, renforcer chiffrement, monitoring des transactions
CRM et gestion relation client	Historique client, réclamations,	Fuite de données vers Salesforce (États-Unis),	Clauses Contractuelles Types	Moyen	Élevé (atteinte vie privée, responsabilité	Élevée	Renégocier CCT Salesforce, MFA

Traitement	Données sensibles	Menaces identifiées	Vulnérabilités	Probabilité	Impact	Criticité	Actions prioritaires
	données de fidélité	accès non autorisé au CRM, modification de dossiers clients, exposition des enregistrements audio	insuffisantes, authentification faible Salesforce, absence de segmentation du réseau, enregistrements audio non chiffrés		civile, perte de confiance)		obligatoire, chiffrer enregistrements
Marketing et prospection	Email, profil de navigation, cookies, données de retargeting	Extraction de données via cookies malveillants, piratage de compte marketing, envoi de spam/phishing depuis compte B&B, violation du consentement	Tarteaucitron mal configuré (durée consentement non respectée), absence de mécanisme d'opt-out robuste, données non chiffrées	Moyen	Moyen (violation RGPD article 21, amendes, détérioration image)	Moyenne	Auditer Tarteaucitron, renforcer opt-out, sensibilisation consentement

Traitement	Données sensibles	Menaces identifiées	Vulnérabilités	Probabilité	Impact	Criticité	Actions prioritaires
Gestion Wi-Fi hôtelier	Logs de connexion, adresse IP, identifiant terminal	Interception Wi-Fi (attaque MITM), accès non autorisé aux données de connexion, violation de l'obligation légale L.34 CPCE	Wi-Fi mal sécurisé (WPA2 insuffisant), logs non chiffrés, accès aux serveurs Wi-Fi insuffisamment contrôlé, absence de segmentation	Élevée	Moyen-Élevé (violation légale, exposition à autorités, atteinte vie privée)	Moyenne	Passer à WPA3, chiffrer logs, limiter accès serveurs
Gestion personnel et RH	Identité, contrat, paie, données sensibles (santé, handicap)	Accès non autorisé aux données RH, fuite de données RH vers tiers, vol de RIB/IBAN, modification de données de paie	Authentification faible SIRH/AES, absence de chiffrement données sensibles RH, habilitations trop larges (tout le personnel peut accéder)	Moyen	Critique (violation confidentialité salarié, responsabilité pénale, démotivation)	Critique	Restreindre accès RH, chiffrer données sensibles, audit SIRH/AES
Vidéoprotection	Images vidéo, données	Vol d'enregistrements	Vidéosurveillance mal signalée,	Faible	Moyen (atteinte vie	Moyenne	Sécuriser serveurs vidéo, affichage

Traitement	Données sensibles	Menaces identifiées	Vulnérabilités	Probabilité	Impact	Criticité	Actions prioritaires
	d'identification (en cas d'incident)	vidéo, modification de preuves, exposition de clients/personnel à leur insu	serveurs vidéo non sécurisés, accès insuffisamment contrôlé, archivage non chiffré		privée, responsabilité civile, violation CNIL)		légal, restreindre accès
Fiches police	Identité étrangers, numéro document, dates séjour	Perte/vol des fiches papier, accès non autorisé aux fiches, exposition avant transmission à police	Stockage papier insuffisamment sécurisé, absence de contrôle d'accès physique, transmission non sécurisée aux autorités	Faible-Moyen	Élevé (violation obligation légale, sanction CNIL, atteinte vie privée étrangers)	Moyenne	Sécuriser stockage papier, chiffrer transmission électronique si possible
Contentieux et sinistres	Données litigieuses, photos/vidéos, correspondances légales	Accès non autorisé aux dossiers, perte de preuves, modification de documents,	Archivage insuffisamment sécurisé, absence de contrôle d'accès granulaire, durée	Faible	Élevé (perte de droits légaux, responsabilité professionnelle,	Moyenne	Restreindre accès aux dossiers, chiffrer archivage

Traitement	Données sensibles	Menaces identifiées	Vulnérabilités	Probabilité	Impact	Criticité	Actions prioritaires
		exposition à avocats non autorisés	conservation excessive		atteinte confidentialité)		